

Task 2 - Network Security & Scanning

OpenVas Vulnerability Report

Student: Rutuja Laxman khade

Operating System: Kali Linux

Target: Metasploitable2

Internship: CyberSecurity and Ethical Hacking company:

Apex Planet Software Pvt. Ltd.

OpenVAS Vulnerability Scan Analysis

Target: 192.168.56.102 | Task: Metasploitable2 Vulnerability Scan

Scan window: Sun Aug 2, 2026, 10:52:46 – 12:11:21 UTC | Report generated: Aug 9, 2026

Introduction

This report presents the results of a vulnerability assessment conducted against a single target host, 192.168.56.102, using OpenVAS (Open Vulnerability Assessment System), the open-source vulnerability scanning engine maintained under the Greenbone Vulnerability Management (GVM) project. The assessment was performed as part of a cybersecurity internship exercise to develop practical experience with vulnerability scanning tools, result interpretation, severity triage, and professional security reporting. The target host's software fingerprint — Ubuntu 8.04, TWiki dated 2003, vsftpd 2.3.4, DistCC, and an Ingreslock backdoor — is consistent with Metasploitable2, a deliberately vulnerable Linux virtual machine distributed by Rapid7 for security training and tool practice. Findings should therefore be read in that context: the host is intentionally insecure, and the value of this exercise is in the process of scanning, triage, and reporting rather than in remediating a live production system.

Objective

The objectives of this assessment were to:

- Perform a full vulnerability scan of the target host using OpenVAS/Green bone.
- Identify and classify vulnerabilities by severity (Critical, High, Medium, Low) using CVSS scoring.
- Analyze the root cause and potential impact of each significant finding.
- Prioritize risks based on exploitability and business/lab impact.
- Produce actionable, prioritized remediation recommendations.
- Document the assessment in a professional, reproducible report format suitable for internship review

Lab Environment

Component	Details
Scanner host OS	Kali Linux / Green bone Community Edition (specify your VM)
Scanner software	OpenVAS / GVM (specify version, e.g. GVM 22.x)
Target VM	Metasploitable2 (Ubuntu 8.04)
Target IP address	192.168.56.102
Scanner IP address	192.168.56.101 (observed in RMI callback evidence)
Network mode	Host-only / isolated NAT network (VirtualBox or VMware)
Network segment	192.168.56.0/24 (isolated lab segment, no internet-routable access)

OpenVAS / Green bone Methodology

OpenVAS operates using a plugin-based architecture in which each check is implemented as a Network Vulnerability Test (NVT), identified by a unique OID. The scanning workflow follows these stages:

- 1.Host Discovery — Identify live hosts on the target network/subnet.
- 2.Port Scanning — Enumerate open TCP/UDP ports on each live host.
- 3.Service & Product Detection — Fingerprint the service and product/version listening on each open port (CPE detection).
- 4.NVT Selection — Select relevant NVTs based on detected services, ports, and products.

5.Vulnerability Testing — Execute active and passive checks — banner analysis, default-credential attempts, crafted protocol requests — to confirm each NVT's condition

6.Severity Scoring — Assign CVSS base scores and map to Critical/High/Medium/Low severity bands.

7. Quality of Detection (QoD) Filtering — Assign confidence percentage to each result and filter lowconfidence detections.

7.Reporting — Aggregate results per host into a structured report, as summarized in this document.

Scan Configuration

Parameter	Value
Task name	Metasploitable2 Vulnerability Scan
Scan config	Full and Fast (or specify custom config used)
Target	192.168.56.102
Port list	All TCP and commonly used UDP ports
Scan start	Sun Aug 2, 2026, 10:52:46 UTC
Scan end	Sun Aug 2, 2026, 12:11:21 UTC
Duration	1 hour 18 minutes
Authentication	SMB credentials succeeded (port 445) - partially authenticated scan
QoD threshold	>=70%
Overrides	Disabled – raw scanner severities reported
Result shown	74 of 598 raw results (post QoD/Log/Debug/False Positive filtering)

Executive Summary

The scan identified 74 results (after QoD $\geq 70\%$ filtering, from 598 raw results) against a single host, 192.168.56.102. This host corresponds to Metasploitable2, a deliberately vulnerable Ubuntu 8.04 system — the finding set is consistent with an intentionally insecure lab/training target rather than a hardened production system. Nonetheless, the pattern of findings is a useful template for how an OpenVAS report should be triaged in any environment. The host has 13 Critical and 9 High severity findings, several of which are pre-installed backdoors (Ingreslock, vsftpd 2.3.4, dRuby) or unauthenticated remote code execution paths (Tomcat Ghostcat, DistCC, TWiki, Java RMI). Multiple services also accept blank or default credentials (MySQL, PostgreSQL, VNC, FTP). Combined, these findings represent full and immediate remote compromise of the host with no authentication required.

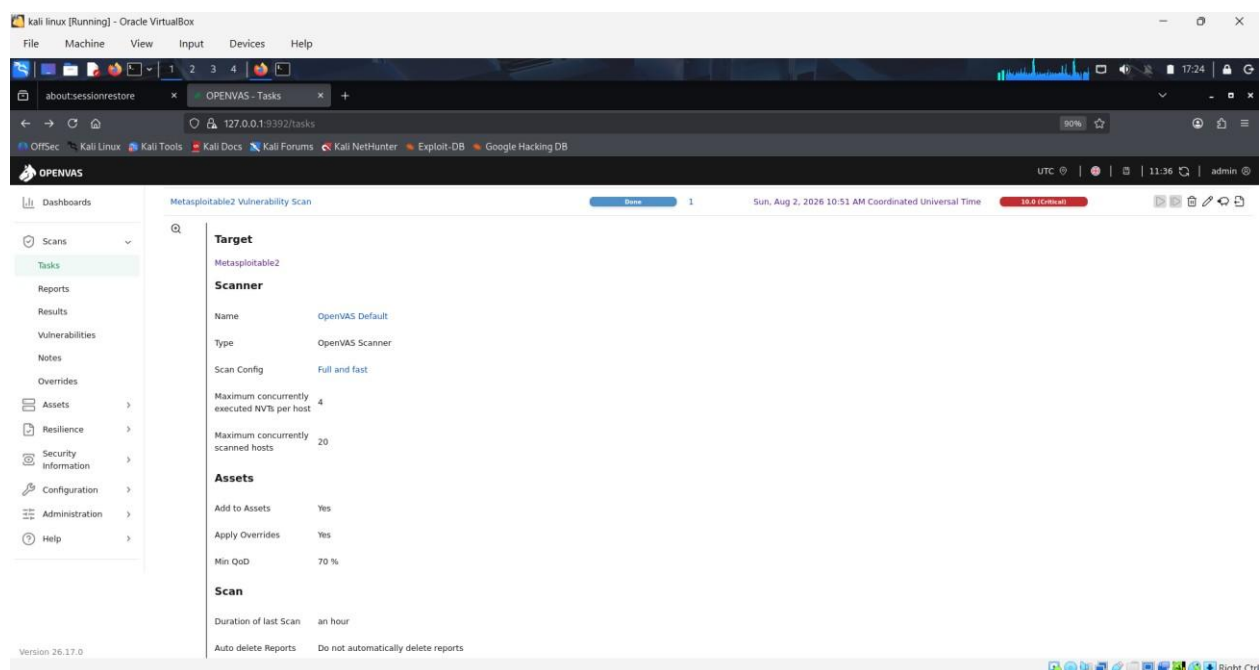


Figure 1: OpenVAS scan task and target configuration for the Metasploitable2 vulnerability assessment.

Findings by Severity

Severity	Count	CVSS Range	Primary Risk
Critical	13	9.0 - 10.0	Unauthenticated remote code execution, default/blank credentials, active backdoors
High	9	7.4 - 7.5	Weak/default FTP credentials, unauthenticated RCE paths, cleartext admin protocols
Medium	43	4.0 - 6.8	Weak TLS/SSH configuration, XSS/CSRF, info disclosure, outdated web components
Low	9	2.1 - 3.7	Protocol fingerprinting, timestamp disclosure, legacy cipher support

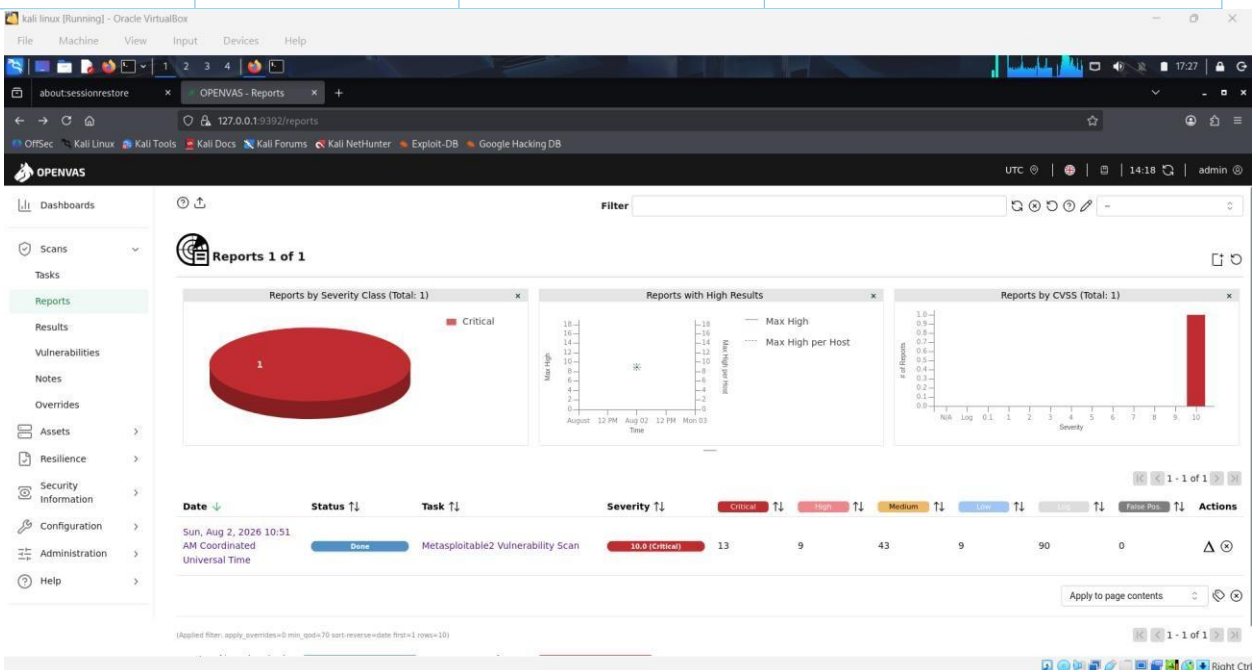


Figure 2: OpenVAS report overview showing the distribution of Critical, High, Medium, and Low vulnerability findings

Critical Findings (13)

All Critical findings carry CVSS scores of 9.0–10.0 and represent direct paths to unauthenticated remote code execution, root-level backdoor access, or full database compromise.

Port/Service	Vulnerability	CVSS	Impact
3306/tcp	MySQL default credentials	9.8	Root login with empty password — full DB compromise
8009/tcp	Apache Tomcat AJP Ghostcat (CVE-20201938)	9.8	Arbitrary file read via AJP connector; can lead to RCE
512/tcp	rexec service running	10.0	Cleartext auth remote command execution service
21/tcp	vsftpd 2.3.4 backdoor (CVE-2011-2523)	9.8	Known malicious backdoor opens root shell on 6200/tcp
80/tcp	TWiki < 4.2.4 XSS / command execution	10.0	Remote Perl code execution via eval injection
8787/tcp	Distributed Ruby (dRuby) RCE	10.0	Unauthenticated arbitrary command/syscall execution
General/tcp	Ubuntu 8.04 End-of-Life OS	10.0	No vendor security patches since 2013
3632/tcp	DistCC RCE (CVE-20042687)	9.3	Unauthenticated arbitrary command execution (confirmed via id)
5900/tcp	VNC weak password ("password")	9.0	Full remote desktop takeover
6200/tcp	vsftpd backdoor shell (confirmed open)	9.8	Direct root shell backdoor confirmed listening
1524/tcp	Ingreslock backdoor	10.0	Pre-installed root shell backdoor, no auth required
513/tcp	rlogin passwordless root login	10.0	Direct root access with no credentials
5432/tcp	PostgreSQL default credentials	9.0	postgres/postgres grants full database access

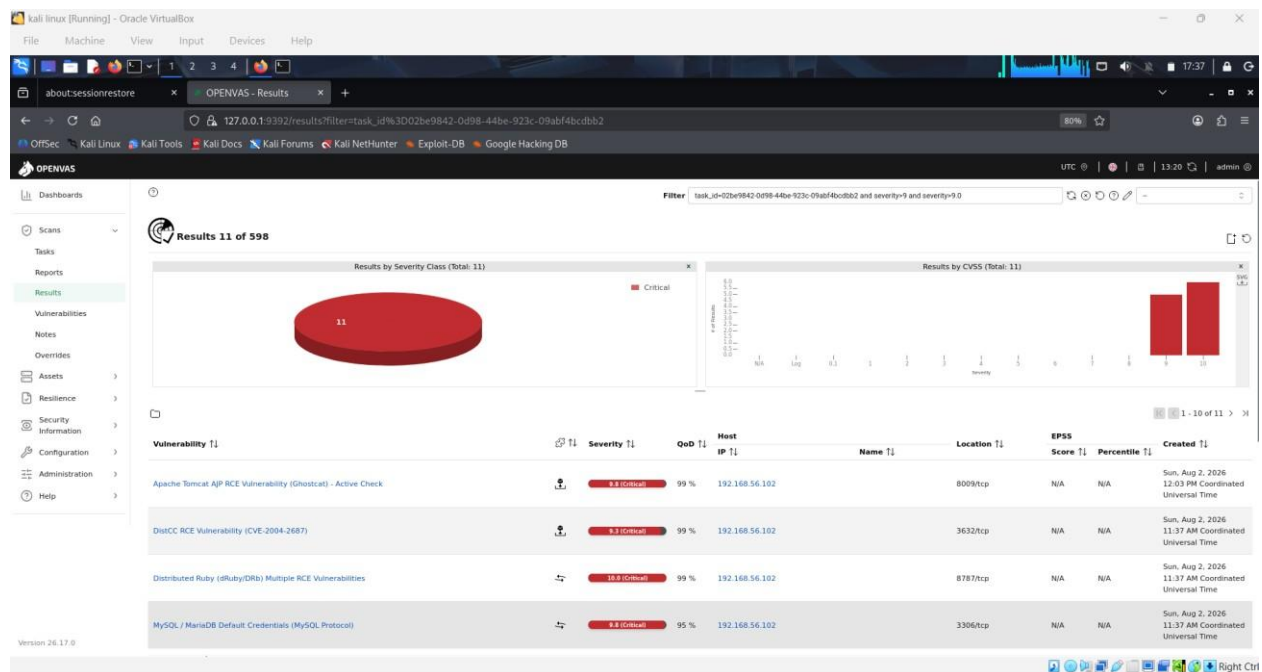


Figure 3: OpenVAS Critical-severity vulnerability results for the Metasploitable2 target.

High Findings (9)

High severity findings (CVSS 7.4–7.5) center on default credentials and unauthenticated code-execution vectors reachable over standard web and RMI ports.

Port/Service	Vulnerability	CVSS	Impact
21/tcp, 2121/tcp	FTP default credentials (msfadmin, postgres, service, user)	7.5	Account takeover / shell access via FTP
80/tcp	PHP-CGI RCE (CVE2012-1823)	7.5	Arbitrary PHP code execution via crafted query string
80/tcp	EasyPHP Webserver auth bypass	7.5	Admin access bypass, info disclosure
80/tcp	HTTP PUT/DELETE enabled	7.5	Arbitrary file upload/deletion on web server
1099/tcp	Java RMI insecure default config RCE	7.5	Unauthenticated remote code execution
514/tcp	rsh unencrypted service	7.5	Cleartext remote shell credentials
513/tcp	rlogin service exposed	7.5	Cleartext authentication, session hijack risk
5432/tcp	OpenSSL CCS MITM bypass (CVE-2014-0224)	7.4	Session hijack via crafted TLS handshake

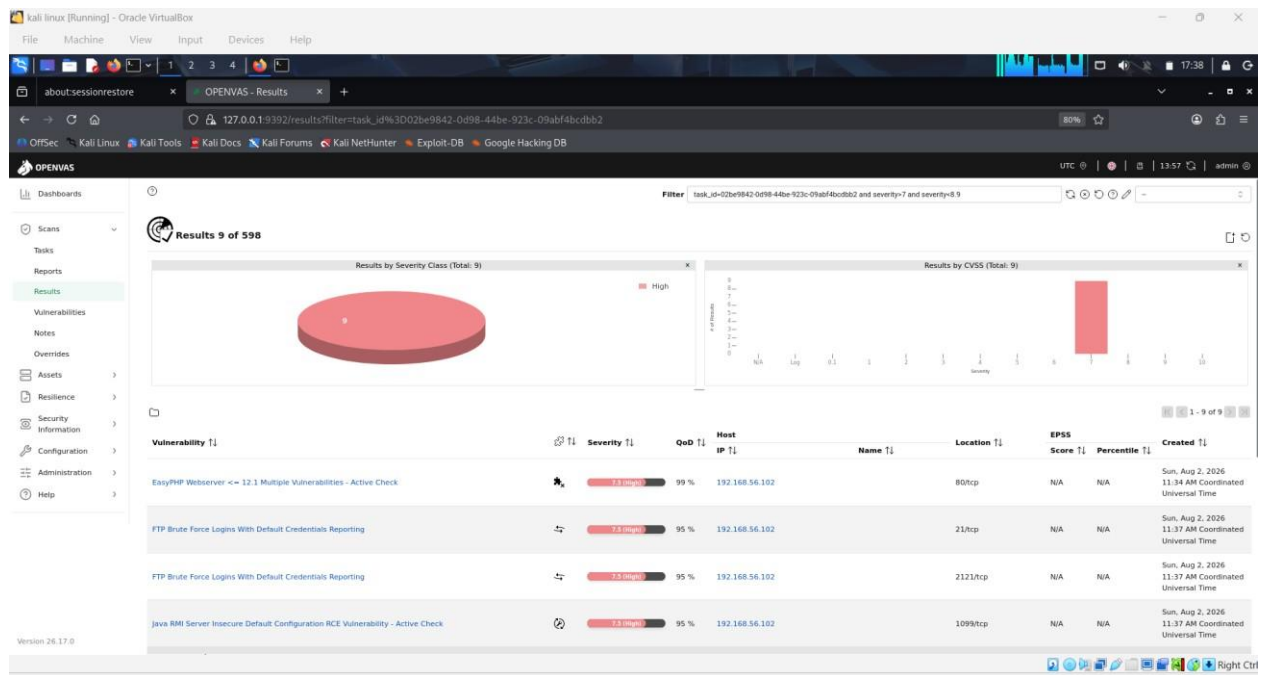


Figure 4: OpenVAS High-severity vulnerability results for the Metasploitable2 target.

Medium Findings (43)

The Medium category is dominated by TLS/SSH configuration weaknesses (deprecated protocols, export ciphers, short keys) and web-application issues (XSS, CSRF, outdated jQuery, exposed phpinfo(), directory traversal). Full detail for all 43 items is in the source OpenVAS PDF; representative findings are grouped below.

Port/Service	Vulnerability	CVSS	Impact
80/tcp	TWiki CSRF / XSS (multiple CVEs)	6.1-6.8	Session/privilege abuse via crafted requests
80/tcp	jQuery 1.3.2 XSS (2 CVEs)	4.3-6.1	Outdated client-side library, script injection
80/tcp	phpinfo() exposed	5.3	Discloses server config, paths, PHP internals
80/tcp	Directory traversal (QwikiWiki, awiki)	5.0	Arbitrary local file read (e.g. /etc/passwd)
445/tcp	Samba 3.0.20 MS-RPC shell command exec	6.0	Remote command execution confirmed via ping test
22/tcp	Weak SSH KEX/MAC/host-key/cipher algorithms	4.3-5.3	Weakens SSH channel confidentiality/integrity
25/tcp	STARTTLS command injection, VRFY/EXPN enabled	5.0-6.8	Credential exposure, user enumeration
5432/5900/25	Deprecated SSLv2/SSLv3/TLSv1.0, weak ciphers, 1024-bit RSA/DH, expired cert	4.0-5.9	Traffic decryption / MITM (POODLE, FREAK, LogJam family)
21/2121/23	Cleartext FTP & Telnet logins, anonymous FTP	4.8-6.4	Credential sniffing, unauthorized file access

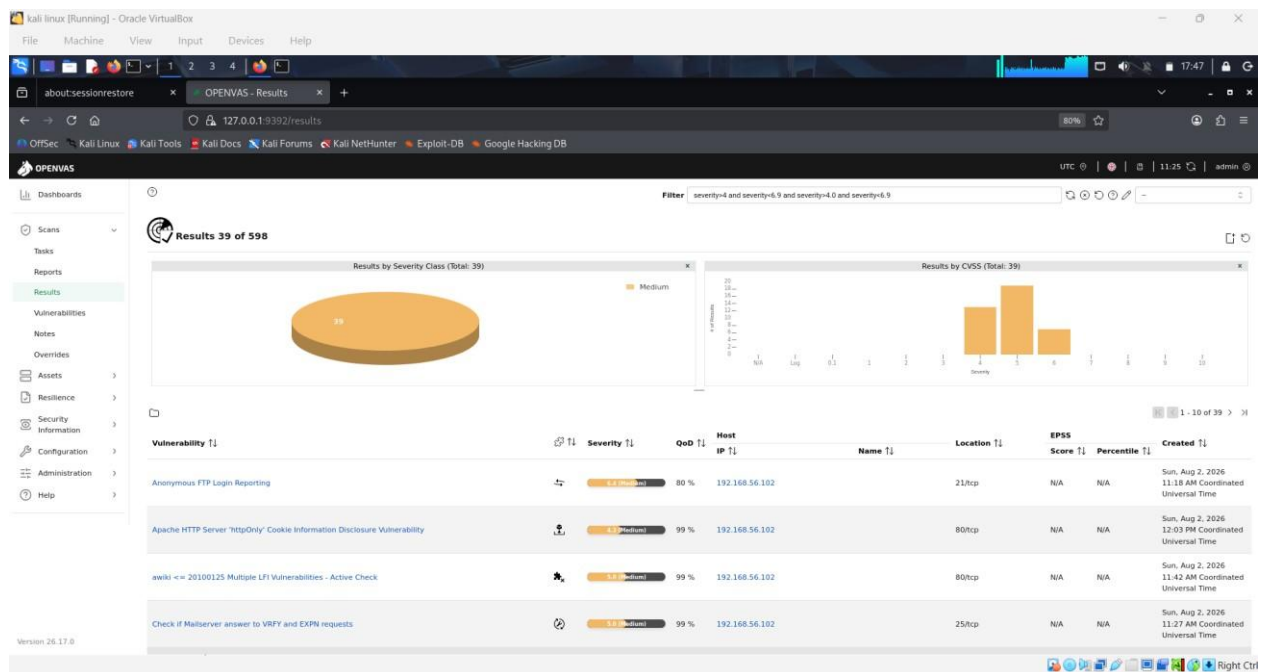


Figure 5: OpenVAS Medium-severity vulnerability results for the Metasploitable2 target.

Low Findings (9)

Low severity findings are primarily reconnaissance-aiding information disclosures and legacy cryptographic protocol support with limited standalone impact.

Port/Service	Vulnerability	CVSS	Impact
general/icmp	ICMP timestamp disclosure	2.1	Minor recon aid for timebased RNG attacks
general/tcp	TCP timestamps expose uptime	2.6	Minor fingerprinting/recon value
25/5432/5900	LogJam / POODLE cipher exposure (SSLv3/DHE_EXPORT)	3.4-3.7	Legacy MITM cipher downgrade paths
22/tcp	Weak SSH MAC algorithms (MD5, 96-bit)	2.6	Reduced integrity assurance on SSH sessions

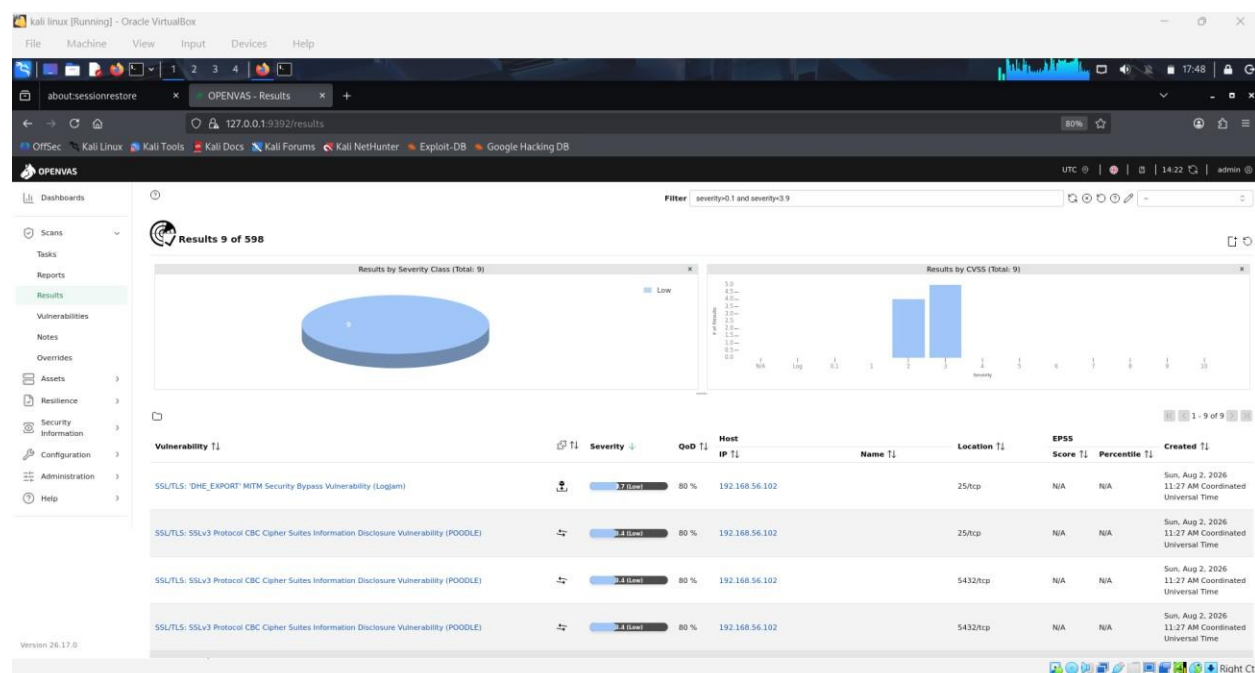


Figure 6: OpenVAS Low-severity vulnerability results for the Metasploitable2 target.

Risk Prioritization

Tier	Category	Representative Findings	Rationale
Tier 1	Active backdoors	vsftpd 2.3.4 (21/6200), Ingreslock (1524), DistCC (3632), dRuby (8787)	Already compromised / trivial unauthenticated RCE
Tier 1	Default credentials on core services	MySQL, PostgreSQL, VNC, FTP	Instant full access, no exploit development needed
Tier 2	Unauthenticated RCE in applications	Tomcat Ghostcat, TWiki, Java RMI, PHP-CGI, Samba	Requires a working exploit but is well-documented / public
Tier 2	Cleartext legacy protocols	Rexec, rlogin, rsh, Telnet	Passive credential capture on the network segment
Tier 3	Weak TLS/SSH configuration	SSLv2/3, TLSv1.0/1.1, weak ciphers, short keys, weak SSH algorithms	Requires active MITM position; lower likelihood in isolated lab
Tier 3	Web-application weaknesses	XSS, CSRF, phpinfo() exposure, directory traversal, outdated jQuery	Requires user interaction or direct HTTP Access
Tier 4	Information disclosure	ICMP/TCP timestamps, expired certs, weak MACs	Recon value; no direct compromise path

Prioritized Remediation Plan

1.Remove/replace all backdoors — Rebuild the host — vsftpd 2.3.4 (6200/tcp), Ingres lock (1524/tcp), DistCC (3632/tcp) and dRuby (8787/tcp) are known-compromised or trivially exploitable services. Patching alone is not sufficient; treat the host as already compromised.

2.Eliminate default/blank credentials — Change or disable default logins for MySQL (root/blank), PostgreSQL (postgres/postgres), VNC ("password"), and FTP (msfadmin, postgres, service, user).

3.Disable legacy remote access services — Turn off rexec, rlogin, rsh, and Telnet. Replace with SSH key-based authentication only.

4.Patch/upgrade exposed applications — Tomcat (Ghostcat), PHP-CGI, TWiki, Samba, jQuery, and PostgreSQL/OpenSSL are all running versions with known, patched RCE or MITM CVEs.

5.Harden TLS/SSH configuration — Disable SSLv2/SSLv3/TLSv1.0/1.1, remove export/RC4/DES ciphers, replace 1024-bit RSA/DH keys and certificates, and disable weak SSH KEX/MAC/host-key algorithms.

6.Reduce web attack surface — Disable HTTP PUT/DELETE and TRACE/TRACK methods, remove exposed phpinfo() files, and fix directory-traversal/LFI issues in wiki components.

7.Retire the underlying OS — Ubuntu 8.04 reached end-of-life in 2013 and receives no security updates — upgrade or decommission.

Notes & Scope Caveats

- Overrides were off — all severities reflect actual detected threats, not analyst-adjusted ratings.

- Only results with Quality of Detection (QoD) $\geq 70\%$ are included; 524 lower-confidence results were filtered out of the original 598.

- Vendor security updates were not trusted/verified against a patch database — all findings are based on active detection/exploitation checks.

- If this is a Metasploitable2 training instance, standard practice is to keep it network-isolated (host-only/NAT, no bridged access) rather than remediate individual findings, since the platform is designed to remain vulnerable for training use.

Conclusion

This assessment identified 74 findings against 192.168.56.102, including 13 Critical and 9 High severity vulnerabilities that together permit full, unauthenticated remote compromise via multiple independent paths — preinstalled backdoors, default credentials, and unpatched remote-code-execution flaws. The 43 Medium and 9 Low findings are primarily weak in cryptographic configuration and outdated web components, which further widen the attack surface but are not immediately exploitable without existing network access.

Given the host's fingerprint, this target is consistent with Metasploitable2, an intentionally vulnerable training platform. As such, the appropriate control is network isolation (host-only/NAT virtual networking, no bridged or internetroutable access) rather than remediation of individual findings, since the platform is designed to remain vulnerable for repeated training use.

This exercise demonstrated the full vulnerability assessment lifecycle: scan configuration, execution, result triage by severity, root-cause analysis, risk prioritization, and remediation planning — the core workflow expected of a security analyst working with automated vulnerability scanning tools.